# SSDL Security & POPIA Compliance

Security Software Development Lifecycle (SSDL), STRIDE Threat Modeling, AES-256-GCM Cryptography & South African Statutory POPIA / DVA Compliance

## 1. SSDL Lifecycle & Threat Model Philosophy

Standard mobile security frameworks protect primarily against remote network attackers. In domestic violence contexts, the primary threat actor is the **Adversary in Physical Possession of the Unlocked Device**. The survivor's intimate partner has coercion capabilities, physical proximity, and the ability to demand device inspection. Umkhuseli's Security Software Development Lifecycle (SSDL) treats physical inspection as the default attack vector across all phases:

| SSDL Phase | Core Focus & Threat Addressed | Engineering Implementation & Controls |
|---|---|---|
| **1. Requirements** | POPIA Data Sovereignty & Domestic Violence Act standards. | Local-first storage policy; Section 4(2) safe address withholding toggle; zero third-party analytics SDKs. |
| **2. Threat Modeling** | STRIDE analysis focused on physical inspection and forced disclosure. | Dual-persona PowerCalc SA utility facade; duress PIN 9999= decoy voucher; 0ms instantaneous memory scrub. |
| **3. Secure Design** | Hardware-backed cryptography; tamper-evident evidence logs. | AndroidKeyStore StrongBox/TEE; AES-256-GCM; random 12-byte IV per record; BiometricPrompt BIOMETRIC_STRONG. |
| **4. Implementation** | Prevention of memory leaks, screenshot leakage, and recent app cards. | Window FLAG_SECURE on vault screens; automated memory zeroing; NetworkPolicyHelper metered connection gating. |
| **5. Verification** | Cryptographic roundtrip verification and offline resilience testing. | Automated unit test suite validating AES-256-GCM decryption, IV uniqueness, and Form 2 evidentiary formatting. |
| **6. Deployment** | Binary hardening against reverse-engineering and tampering. | ProGuard / R8 code shrinking and symbol obfuscation; APK signature v2/v3; Vercel edge deployment with clean domain hosting. |

## 2. Cryptographic Architecture & Specifications

All sensitive victim narratives, medical examination notes, and witness names are encrypted before being written to SQLite disk. The cryptographic layer is implemented via VaultEncryptionHelper utilizing Java Cryptography Architecture (JCA) on Android and Web Crypto API (SubtleCrypto) on Vercel PWA:

- **Master Key Isolation:** Keys generated via KeyGenerator.getInstance(KEY_ALGORITHM_AES, 'AndroidKeyStore'). Keys are hardware-bound inside the device's Trusted Execution Environment (TEE) or StrongBox chip, preventing extraction even on rooted devices.
- **Cipher & Mode:** Authenticated **AES-256-GCM (Galois/Counter Mode)** without padding (AES/GCM/NoPadding). GCM provides both confidentiality and data authenticity via a 128-bit authentication tag.
- **Initialization Vector (IV):** Every single record is encrypted with a cryptographically secure, uniquely generated **12-byte IV**. The IV is prepended to the ciphertext payload: [IV (12 bytes)] + [Ciphertext + Auth Tag]. Replay attacks and ciphertext pattern matching are mathematically impossible.
- **ECTA Section 15 Tamper-Evidence:** Incidents are hashed via SHA-256 to create an immutable evidentiary audit trail satisfying Section 15 of the Electronic Communications and Transactions Act (Act 25 of 2002).
- **Memory Zeroing & Scrubbing:** When the survivor triggers panic camouflage (Back key, Escape, or Quick-Exit), decrypted strings and secret key references held in ViewModel StateFlows are immediately overwritten or garbage collected synchronously in 0 ms.

# 3. Statutory Compliance: POPIA, DVA & UAT Data Ethics

## Protection of Personal Information Act (POPIA Act 4 of 2013)

Survivor trauma data constitutes **Special Personal Information** under Section 26 of POPIA. Umkhuseli enforces compliance through strict zero-telemetry architecture:

- **Local-First Storage:** 100% of incident records reside exclusively on the survivor's handset.
- **Zero Analytics / Ad SDKs:** No third-party marketing SDKs, trackers, or telemetry beacons exist in the codebase.
- **Anonymous UAT Feedback:** Live device testing feedback (submitted to Supabase `uat_feedback_submissions`) uses ephemeral session IDs without phone numbers, legal names, or GPS coordinates.
- **Data Sovereignty:** The survivor retains unilateral power to purge the vault with a single wipe command.

## Domestic Violence Act (Act 116 of 1998, as amended by Act 14 of 2021)

To ensure victim affidavits are accepted by Magistrates Courts, Umkhuseli incorporates statutory legal mandates:

- **Section 4(1) Form 2 Standards:** Captures statutory complainant particulars, respondent details, and date/time records.
- **Section 4(2) Safe Address Withholding:** Explicitly provides the legal right for complainants to withhold their physical residential address on court applications if disclosure would endanger their safety.
- **J88 Clinical Examination Alignment:** Standardized logging of physical trauma, bodily injuries, and attending clinician notes.

**OWASP MOBILE COMPLIANCE**

**OWASP Mobile Top 10 Alignment:** Umkhuseli satisfies M1 (Improper Credential Usage - StrongBox Keymaster), M2 (Inadequate Supply Chain - zero untrusted dependencies), M4 (Insufficient Input Validation - parameterized Room queries), and M10 (Insufficient Cryptography - AES-256-GCM).